# BÁO CÁO LỖI (DEFECT / BUG REPORT)

## Môn học: Kiểm thử phần mềm (HW02)

> **Sinh viên thực hiện**: 23120346
> **Repository GitHub nhóm**: https://github.com/tinphan247/-KTPM-2026-HW02-Domain-Testing
> **Hệ thống kiểm thử (SUT)**: EShop (Web & Backend)

## TỔNG HỢP DANH SÁCH BUG TÌM ĐƯỢC CHO TÍNH NĂNG FR-03

| Bug ID | Tên Lỗi (Defect Summary) | Mức độ (Severity) | Trạng thái trên GitHub Issues |
|---|---|---|---|
| **BUG-FR03-01** | Thiếu hoàn toàn trường "Xác nhận mật khẩu mới" trên giao diện Bước 2 | **High** | Issue #39 |
| **BUG-FR03-02** | Hệ thống chỉ sinh và chấp nhận mã OTP 4 chữ số thay vì 6 chữ số theo đặc tả | **High** | Issue #40 |
| **BUG-FR03-03** | Regex kiểm tra mật khẩu sai logic: Từ chối ký tự đặc biệt hợp lệ và bắt buộc chứa khoảng trắng | **Critical** | Issue #41 |
| **BUG-FR03-04** | Trường nhập Email dùng thẻ `type="text"` thay vì `type="email"` vi phạm chuẩn HTML5 và tiêu chuẩn GUI | **Medium** | Issue #42 |
| **BUG-FR03-05** | Giao diện quy trình 2 bước không có chỉ báo bước (Step Indicator "Bước 1 / 2") | **Low** | Issue #43 |
| **BUG-FR03-06** | Backend API thiếu hoàn toàn kiểm tra độ phức tạp mật khẩu, chấp nhận mật khẩu yếu "123" (CWE-602) | **High** | Issue #44 |
| **BUG-FR03-07** | Mật khẩu sau khi reset bị lưu dưới dạng văn bản thô (Plaintext) vào CSDL SQLite (Vi phạm nghiêm trọng SEC-01) | **Critical** | Issue #45 |
| **BUG-FR03-08** | **[AI BỎ SÓT - HUMAN FOUND]** Thiếu thuộc tính `autocomplete="off"` khiến trình duyệt tự động điền Email vào ô OTP và Mật khẩu lưu vào ô Mật khẩu mới | **Medium** | Issue #46 |

## CHI TIẾT TỪNG BUG BÁO CÁO (DEFECT DETAILS)

### 1. BUG-FR03-01: Thiếu trường "Xác nhận mật khẩu mới" trên giao diện Bước 2

- **Mã Bug**: `BUG-FR03-01`
- **Tính năng**: `FR-03: Quên mật khẩu & Đặt lại mật khẩu`
- **Mức độ nghiêm trọng (Severity)**: **High**
- **Môi trường kiểm thử**: Chrome 129 / Windows 11 / `http://localhost:5173/forgot-password`
- **Người phát hiện**: 23120346
- **Đặc tả yêu cầu (Specification)**:

  > *"Bước 2 — Đặt lại mật khẩu: Người dùng nhập OTP, Mật khẩu mới, và Xác nhận mật khẩu mới... Phải có trường Xác nhận mật khẩu — hệ thống từ chối nếu hai trường không khớp."*

- **Các bước tái hiện (Steps to Reproduce)**:
  1. Truy cập `http://localhost:5173/forgot-password`.
  2. Nhập email `test@eshop.com`, nhấn "Lấy mã OTP".
  3. Quan sát giao diện Bước 2 hiện ra.
- **Kết quả thực tế (Actual Result)**: Giao diện Bước 2 chỉ có duy nhất 2 trường nhập: "Mã OTP (4 số)" và "Mật khẩu mới". Hoàn toàn không có trường "Xác nhận mật khẩu mới".
- **Kết quả mong đợi (Expected Result)**: Phải có trường "Xác nhận mật khẩu mới" để người dùng nhập lại mật khẩu và hệ thống kiểm tra sự trùng khớp.

- **Bằng chứng (Screenshots)**:
  - Ảnh chụp giao diện (thiếu ô Confirm Password): `screenshots/FR03_BUG01_MISSING_CONFIRM_PASSWORD.png`
  - Ảnh chụp mã nguồn React (khoanh vùng thiếu ô input): `screenshots/FR03_BUG01_CODE_EVIDENCE.png`

---

### 2. BUG-FR03-02: Backend và Giao diện chỉ sinh OTP 4 chữ số thay vì 6 chữ số

- **Mã Bug**: `BUG-FR03-02`
- **Tính năng**: `FR-03: Quên mật khẩu & Đặt lại mật khẩu`
- **Mức độ nghiêm trọng (Severity)**: **High**
- **Đặc tả yêu cầu (Specification)**:

> *"Hệ thống sinh mã OTP 6 chữ số ngẫu nhiên..."* (Đồng thời tiêu chuẩn bảo mật SEC-07: *"OTP đặt lại mật khẩu phải đủ entropy, tối thiểu 6 chữ số"*).

- **Các bước tái hiện (Steps to Reproduce)**:
  1. Truy cập `http://localhost:5173/forgot-password`.
  2. Nhập `test@eshop.com`, nhấn "Lấy mã OTP".
  3. Đọc mã OTP được thông báo trên màn hình và đọc nhãn trường nhập.
- **Kết quả thực tế (Actual Result)**:
  - Backend (`backend/server.js` dòng 72) sử dụng công thức: `Math.floor(1000 + Math.random() * 9000).toString()` chỉ sinh số có 4 chữ số (từ 1000 đến 9999).
  - Giao diện hiển thị nhãn: `"Mã OTP (4 số)"` và mã OTP chỉ có 4 số (ví dụ: `1619`).
- **Kết quả mong đợi (Expected Result)**: Hệ thống phải sinh mã OTP ngẫu nhiên gồm đúng 6 chữ số (từ 100000 đến 999999).
- **Bằng chứng (Screenshots)**:
  - Ảnh chụp giao diện: `screenshots/FR03_BUG02_OTP_4DIGITS_INSTEAD_OF_6.png`
  - Ảnh chụp API Response & Code Backend (khoanh vùng lỗi 4 số): `screenshots/FR03_BUG02_API_EVIDENCE.png`

---

### 3. BUG-FR03-03: Regex kiểm tra mật khẩu bị lỗi logic nghiêm trọng (yêu cầu khoảng trắng thay vì ký tự đặc biệt)

- **Mã Bug**: `BUG-FR03-03`
- **Tính năng**: `FR-03: Quên mật khẩu & Đặt lại mật khẩu`
- **Mức độ nghiêm trọng (Severity)**: **Critical**
- **Đặc tả yêu cầu (Specification)**:

> *"Mật khẩu tối thiểu 8 ký tự, có ít nhất 1 chữ hoa, 1 chữ thường, 1 chữ số và 1 ký tự đặc biệt (@, $, !, %, , ?, &)."

- **Các bước tái hiện (Steps to Reproduce)**:
  1. Tại Bước 2 của trang Quên mật khẩu, nhập OTP hợp lệ.
  2. Nhập mật khẩu hợp lệ chuẩn theo đặc tả: `Eshop@2026` (10 ký tự, có hoa, thường, số, ký tự đặc biệt `@`).
  3. Nhấn "Đặt lại mật khẩu".
- **Kết quả thực tế (Actual Result)**: Hệ thống bật thông báo lỗi: *"Mật khẩu quá yếu! Phải dài tối thiểu 8 ký tự, gồm chữ hoa, chữ thường, số và KÝ TỰ ĐẶC BIỆT."* *Nguyên nhân mã nguồn:* Tại `frontend-web/src/pages/ForgotPassword.jsx` dòng 26: `const flawedStrongPasswordRegex = /^(?=.*[a-z])(?=.*[A-Z])(?=.*\d)(?=.*\s)[A-Za-z\d\s]{8,}$/;` Regex này sử dụng `(?=.*\s)` đòi hỏi phải có **khoảng trắng**, và tập ký tự cho phép chỉ gồm chữ và số và khoảng trắng `[A-Za-z\d\s]`, hoàn toàn không cho phép các ký tự đặc biệt `@, $, !, %, *, ?, &`! Nếu nhập mật khẩu có khoảng trắng như `Eshop 2026` thì lại pass.
- **Kết quả mong đợi (Expected Result)**: Hệ thống phải chấp nhận mật khẩu có chứa các ký tự đặc biệt `@, $, !, %, *, ?, &` như `Eshop@2026`.
- **Bằng chứng (Screenshots)**:
  - Ảnh chụp giao diện từ chối mật khẩu hợp lệ: `screenshots/FR03_BUG03_REGEX_REJECTS_VALID_PASSWORD.png`
  - Ảnh chụp giao diện chấp nhận mật khẩu có dấu cách: `screenshots/FR03_BUG03_REGEX_ACCEPTS_SPACE_PASSWORD.png`
  - Ảnh chụp mã nguồn Regex & đo lường runtime (khoanh đỏ lỗi): `screenshots/FR03_BUG03_CODE_EVIDENCE.png`

---

### 4. BUG-FR03-04: Trường Email dùng `type="text"` thay vì `type="email"`

- **Mã Bug**: `BUG-FR03-04`
- **Tính năng**: `FR-03: Quên mật khẩu` & `FR-22: Form Requirements`

- **Mức độ nghiêm trọng (Severity)**: **Medium**
- **Đặc tả yêu cầu (Specification)**:

> *"FR-22: Trường Email phải dùng `type=\"email\"` (có validate HTML5 format)".*

- **Kết quả thực tế (Actual Result)**: Tại `ForgotPassword.jsx` dòng 50, thẻ input khai báo là `type="text"`. Khi người dùng nhập chuỗi không đúng định dạng email (ví dụ: `testeshop.com`), trình duyệt không kích hoạt tính năng kiểm tra định dạng HTML5 có sẵn của trình duyệt.
- **Kết quả mong đợi (Expected Result)**: Thẻ input phải là `<input type="email" ... />`.
- **Bằng chứng (Screenshots)**:
  - Ảnh chụp giao diện gửi email sai cú pháp: `screenshots/FR03_BUG04_EMAIL_TYPE_TEXT.png`
  - Ảnh chụp mã nguồn thẻ input (khoanh đỏ): `screenshots/FR03_BUG04_CODE_EVIDENCE.png`

---

### 5. BUG-FR03-05: Thiếu Step Indicator ("Bước 1 / 2")

- **Mã Bug**: `BUG-FR03-05`
- **Tính năng**: `FR-03` & `FR-22`
- **Mức độ nghiêm trọng (Severity)**: **Low**
- **Đặc tả yêu cầu (Specification)**:

> *"Giao diện phải hiển thị chỉ báo bước (Step Indicator) — ví dụ: 'Bước 1 / 2'. Các form có từ 2 bước trở lên phải có Step Indicator rõ ràng."*

- **Kết quả thực tế (Actual Result)**: Giao diện chỉ hiển thị tiêu đề "Quên Mật Khẩu", không có bất kỳ thành phần nào chỉ rõ người dùng đang ở Bước 1 hay Bước 2.
- **Kết quả mong đợi (Expected Result)**: Hiển thị thanh chỉ báo bước (Step Indicator) trực quan.
- **Bằng chứng (Screenshot)**:
  - Ảnh chụp giao diện thiếu Step Indicator: `screenshots/FR03_BUG05_MISSING_STEP_INDICATOR.png`

---

### 6. BUG-FR03-06: Backend API thiếu hoàn toàn kiểm tra độ phức tạp mật khẩu (CWE-602)

- **Mã Bug**: `BUG-FR03-06`
- **Tính năng**: `FR-03: Quên mật khẩu & Đặt lại mật khẩu`
- **Mức độ nghiêm trọng (Severity)**: **High**
- **Đặc tả yêu cầu (Specification)**:

> *"Mật khẩu tối thiểu 8 ký tự, có ít nhất 1 chữ hoa, 1 chữ thường, 1 chữ số và 1 ký tự đặc biệt (@, $, !, %, , ?, &)."

- **Các bước tái hiện (Steps to Reproduce)**:
  1. Gửi request HTTP `POST /api/reset-password` trực tiếp đến Backend với payload: `{"email": "test@eshop.com", "resetToken": "<valid_token>", "newPassword": "123"}`
- **Kết quả thực tế (Actual Result)**: Backend trả về HTTP 200: `{"message": "Password reset successfully"}`. Backend hoàn toàn không có bất kỳ logic kiểm tra độ dài hay độ phức tạp của mật khẩu, phó mặc hoàn toàn cho Client-side validation (Lỗ hổng CWE-602).
- **Kết quả mong đợi (Expected Result)**: Backend phải validate lại độ mạnh mật khẩu và trả về lỗi HTTP 400 Bad Request nếu mật khẩu không đạt chuẩn.
- **Bằng chứng (Screenshot)**:
  - Ảnh chụp API Response chấp nhận mật khẩu "123" (khoanh đỏ): `screenshots/FR03_BUG06_API_EVIDENCE.png`

---

### 7. BUG-FR03-07: Mật khẩu lưu dạng văn bản thô (Plaintext) vào CSDL SQLite (Vi phạm SEC-01)

- **Mã Bug**: `BUG-FR03-07`
- **Tính năng**: `FR-03: Quên mật khẩu` & `SEC-01: Security Requirements`
- **Mức độ nghiêm trọng (Severity)**: **Critical**
- **Đặc tả yêu cầu (Specification)**:

> *"SEC-01: Mật khẩu KHÔNG được lưu dưới dạng plaintext."*

- **Các bước tái hiện (Steps to Reproduce)**:
  1. Tiến hành đặt lại mật khẩu thành công qua API hoặc UI.

2. Dùng script hoặc SQLite client truy vấn bảng `users`: `SELECT id, email, password FROM users WHERE email = 'test@eshop.com';`

- **Kết quả thực tế (Actual Result)**: Mật khẩu mới được lưu dưới dạng chữ thô nguyên bản (`123` hoặc `Eshop 2026`) mà không hề được băm (hash) bằng bcrypt hay bất kỳ thuật toán băm an toàn nào (`server.js:90`: `UPDATE users SET password = ? ...`).
- **Kết quả mong đợi (Expected Result)**: Mật khẩu phải được hash trước khi lưu vào CSDL (ví dụ dùng `bcrypt.hash(newPassword, 10)`).
- **Bằng chứng (Screenshot)**:
  - Ảnh chụp truy vấn SQLite lưu mật khẩu Plaintext (khoanh đỏ): `screenshots/FR03_BUG07_DB_EVIDENCE.png`

---

### 8. BUG-FR03-08: [AI BỎ SÓT - HUMAN FOUND] Thiếu thuộc tính `autocomplete="off"` gây lỗi Browser Autofill Misdirection

- **Mã Bug**: `BUG-FR03-08`
- **Tính năng**: `FR-03: Quên mật khẩu & Đặt lại mật khẩu`
- **Mức độ nghiêm trọng (Severity)**: **Medium**
- **Nguồn phát hiện**: **Do Sinh viên (Human Tester) phát hiện thực tế khi trải nghiệm người dùng; AI hoàn toàn bỏ sót!**
- **Đặc tả yêu cầu (Specification & UX Best Practice)**:

> *"Trường Mã OTP phải nhận chuỗi mã OTP xác thực tạm thời; không được để cơ chế tự động điền (Autofill) của trình duyệt ghi đè tài khoản cá nhân vào trường OTP."*

- **Các bước tái hiện (Steps to Reproduce)**:
  1. Người dùng sử dụng trình duyệt thông dụng (Chrome, Edge) có lưu sẵn tài khoản/mật khẩu cá nhân (ví dụ tài khoản Google hoặc tài khoản web bất kỳ).
  2. Tại Bước 1, nhập email hợp lệ rồi bấm "Lấy mã OTP".
  3. Khi hệ thống chuyển sang Bước 2.
- **Kết quả thực tế (Actual Result)**: Do trong `ForgotPassword.jsx`, lập trình viên đặt một `<form>` chứa một ô `<input type="text">` đi liền kề trước một ô `<input type="password">` mà **hoàn toàn không có thuộc tính** `autocomplete="off"` **hoặc** `autocomplete="one-time-code"`:
  - Trình duyệt kích hoạt thuật toán Autofill Password Manager và lầm tưởng đây là một **Form Đăng Nhập bình thường**!
  - Trình duyệt tự động điền địa chỉ email của người dùng (trong ảnh thực tế hiển thị email `tvquang.working@gmail.com`) vào ngay ô `"Mã OTP (4 số)"`, và tự động điền mật khẩu cũ lưu sẵn vào ô `"Mật khẩu mới"`!
  - Hậu quả: Người dùng nếu không để ý mà bấm submit thì sẽ bị báo lỗi "Mã OTP không đúng", đồng thời phải tốn công xóa thủ công chuỗi email bị autofill nhầm.
- **Kết quả mong đợi (Expected Result)**: Ô nhập mã OTP phải có thuộc tính `autoComplete="off"` hoặc `autoComplete="one-time-code"`. Ô nhập mật khẩu mới phải có `autoComplete="new-password"` để ngăn chặn trình duyệt autofill sai mục đích.
- **Bằng chứng (Screenshot)**:
  - Ảnh chụp màn hình lỗi Autofill tài khoản cá nhân vào ô OTP: `screenshots/FR03_BUG08_BROWSER_AUTOFILL_MISDIRECTION.png`

---

## TỔNG HỢP DANH SÁCH BUG CHO CÁC TÍNH NĂNG CÒN LẠI

### 🛒 TÍNH NĂNG B: FR-07 — GIỎ HÀNG (SHOPPING CART)

| Bug ID | Tên Lỗi (Defect Summary) | Mức độ | Bằng chứng UI | Bằng chứng Code | GitHub Issue |
|---|---|---|---|---|---|
| **BUG-FR07-02** | Thêm cùng sản phẩm bị nhân bản dòng mới thay vì cộng dồn số lượng | **High** | `screenshots/FR07_BUG02_DUPLICATE_PRODUCT_ROWS.png` | `screenshots/FR07_BUG02_CODE_EVIDENCE.png` | Issue #47 |

| Bug ID | Tên Lỗi (Defect Summary) | Mức độ | Bằng chứng UI | Bằng chứng Code | GitHub Issue |
|---|---|---|---|---|---|
| **BUG-FR07-03** | Nút "Xóa" sản phẩm thực hiện xóa tức thì, thiếu Confirmation Dialog theo đặc tả | **Medium** | `screenshots/FR07_BUG03_NO_DELETE_CONFIRMATION.png` | `screenshots/FR07_BUG03_CODE_EVIDENCE.png` | Issue #48 |

**Chi tiết Bug tiêu biểu FR-07:**

1. **BUG-FR07-02: Thêm cùng sản phẩm bị nhân bản dòng mới**:
   - *Đặc tả*: "*Thêm cùng một sản phẩm vào giỏ sẽ tăng số lượng, không tạo dòng mới*".
   - *Các bước tái hiện*:
     1. Thêm sản phẩm "iPhone 15 Pro Max" vào giỏ hàng.
     2. Quay lại trang chi tiết sản phẩm, bấm Thêm vào giỏ hàng lần thứ 2.
     3. Mở giỏ hàng `/cart`.
   - *Kết quả thực tế*: Giỏ hàng hiển thị 2 dòng riêng biệt cho cùng sản phẩm iPhone 15 Pro Max thay vì 1 dòng với số lượng = 2.
   - *Mã nguồn lỗi*: `frontend-web/src/context/CartContext.jsx:9` dùng `setCart([...cart, { ...product, quantity }])` không kiểm tra trùng lặp ID.
   - *Bằng chứng*:
     - Ảnh chụp giao diện (2 dòng trùng nhau): `screenshots/FR07_BUG02_DUPLICATE_PRODUCT_ROWS.png`
     - Ảnh chụp mã nguồn khoanh đỏ: `screenshots/FR07_BUG02_CODE_EVIDENCE.png`
2. **BUG-FR07-03: Nút Xóa sản phẩm thiếu hộp thoại xác nhận**:
   - *Đặc tả*: "*Nút Xóa sản phẩm phải có dialog xác nhận trước khi thực hiện*".
   - *Các bước tái hiện*:
     1. Mở giỏ hàng `/cart` có sản phẩm.
     2. Bấm vào nút màu đỏ "Xóa" ở bất kỳ dòng nào.
   - *Kết quả thực tế*: Dòng sản phẩm bị xóa mất ngay lập tức khỏi bảng, không có bất kỳ pop-up confirm hay dialog xác nhận nào.
   - *Mã nguồn lỗi*: `frontend-web/src/pages/Cart.jsx:51` gọi trực tiếp `removeFromCart(index)` trong sự kiện `onClick`.
   - *Bằng chứng*:
     - Ảnh chụp giao diện thao tác Xóa: `screenshots/FR07_BUG03_NO_DELETE_CONFIRMATION.png`
     - Ảnh chụp mã nguồn khoanh đỏ: `screenshots/FR07_BUG03_CODE_EVIDENCE.png`

---

## 📦 TÍNH NĂNG C: FR-15 — QUẢN LÝ SẢN PHẨM ADMIN (PRODUCT CRUD)

| Bug ID | Tên Lỗi (Defect Summary) | Mức độ | Bằng chứng (Screenshot / Evidence) | GitHub Issue |
|---|---|---|---|---|
| **BUG-FR15-01** | Broken Access Control: API POST/PUT/DELETE `/api/products` không cần Token hay quyền Admin (CWE-306) | **Critical** | `screenshots/FR15_BUG01_API_EVIDENCE.png` | Issue #49 |
| **BUG-FR15-02** | Backend và Giao diện Admin chấp nhận thêm/sửa sản phẩm với Giá âm ( `price = -50000` ), vi phạm ràng buộc số dương | **High** | UI: `screenshots/FR15_BUG02_NEGATIVE_PRICE_ACCEPTED.png` API: `screenshots/FR15_BUG02_API_EVIDENCE.png` | Issue #50 |
| **BUG-FR15-02B** | Backend và Admin chấp nhận Giá bằng 0 ₫ (Điểm biên $LB-1=0$ vi phạm đặc tả giá > 0) | **Medium** | UI: `screenshots/FR15_BUG02B_ZERO_PRICE_ACCEPTED.png` | Issue #59 |
| **BUG-FR15-03** | Backend API chấp nhận Tên sản phẩm rỗng ( `""` ), thiếu Server-side validation (CWE-20) | **Medium** | API: `screenshots/FR15_BUG03_EMPTY_NAME_API_EVIDENCE.png` | Issue #55 |

| Bug ID | Tên Lỗi (Defect Summary) | Mức độ | Bằng chứng (Screenshot / Evidence) | GitHub Issue |
|---|---|---|---|---|
| **BUG-FR15-05** | Giao diện Admin: Sửa 1 sản phẩm làm toàn bộ sản phẩm trên UI bị đổi tên theo ( `fakeMassUpdatedProducts` ) | **High** | UI: `screenshots/FR15_BUG05_MASS_UI_OVERWRITE.png` Code: `screenshots/FR15_BUG05_CODE_EVIDENCE.png` | Issue #51 |
| **BUG-FR15-07** | Backend API chấp nhận Giá tiền là chuỗi chữ ( `"mot trieu"` ), thiếu kiểm tra kiểu số gây lỗi tính toán ( `NaN` ) | **High** | API: `screenshots/FR15_BUG07_STRING_PRICE_API_EVIDENCE.png` | Issue #56 |
| **BUG-FR15-08** | Backend chấp nhận Danh mục ảo không tồn tại ( `category_id = 99999` ), thiếu Foreign Key Constraint | **Medium** | API: `screenshots/FR15_BUG08_FAKE_CATEGORY_API_EVIDENCE.png` | Issue #57 |
| **BUG-FR15-10** | API trả về HTTP `200 OK` kèm `{}` khi ID sản phẩm không tồn tại (Thay vì HTTP `404 Not Found` ), gây lỗi trắng trang Client | **Medium** | API: `screenshots/FR15_BUG10_STATUS_200_NOT_FOUND_API_EVIDENCE.png` | Issue #58 |

### Chi tiết Bug tiêu biểu FR-15:

1. **BUG-FR15-01: Broken Access Control trên API Sản phẩm**:
   - *Đặc tả (FR-12 & SEC-02)*: Quản lý sản phẩm chỉ dành cho tài khoản Admin, bắt buộc kiểm tra JWT Token và role='admin'.
   - *Thực tế*: `server.js:167-196` hoàn toàn không có middleware xác thực, anonymous user có thể xóa sạch database sản phẩm.
   - *Bằng chứng*: `screenshots/FR15_BUG01_API_EVIDENCE.png`
2. **BUG-FR15-02 & BUG-FR15-02B: Vi phạm miền giá trị tiền (Giá âm & Giá = 0)**:
   - *Đặc tả*: "*Giá sản phẩm: bắt buộc, phải là số dương (> 0)*".
   - *Thực tế*: Admin Form và Backend API đều không kiểm tra $price > 0$. Người dùng nhập `-50000` hoặc `0` đều được lưu thành công vào CSDL.
   - *Bằng chứng*:
     - Giao diện lưu giá âm: `screenshots/FR15_BUG02_NEGATIVE_PRICE_ACCEPTED.png`
     - Giao diện lưu giá 0: `screenshots/FR15_BUG02B_ZERO_PRICE_ACCEPTED.png`
     - API chấp nhận giá âm: `screenshots/FR15_BUG02_API_EVIDENCE.png`
3. **BUG-FR15-05: Lỗi Mass UI Overwrite khi sửa sản phẩm trong Admin**:
   - *Đặc tả*: "*Khi Sửa một sản phẩm, chỉ sản phẩm đó bị thay đổi — các sản phẩm khác giữ nguyên*".
   - *Thực tế*: `frontend-admin/src/App.jsx:110` dùng `fakeMassUpdatedProducts = products.map(p => ({ ...p, name: productForm.name }))` , đổi tên toàn bộ sản phẩm trong danh sách!
   - *Bằng chứng*:
     - Giao diện bị đổi hàng loạt: `screenshots/FR15_BUG05_MASS_UI_OVERWRITE.png`
     - Code lỗi: `screenshots/FR15_BUG05_CODE_EVIDENCE.png`

---

## 📱 TÍNH NĂNG D: FR-04 MOBILE — QUẢN LÝ HỒ SƠ CÁ NHÂN (PROFILE MANAGEMENT)

| Bug ID | Tên Lỗi (Defect Summary) | Mức độ | Bằng chứng (Screenshot) | GitHub Issue |
|---|---|---|---|---|
| **BUG-FR04-01** | Regex Số điện thoại cấm số 0 ở đầu, từ chối toàn bộ số điện thoại hợp lệ theo đặc tả | **High** | UI: `screenshots/FR04_BUG01_INVALID_PHONE_REJECTED.png` UI Input: `screenshots/FR04_BUG01_VALID_PHONE_INPUT.png` Code: `screenshots/FR04_BUG01_CODE_EVIDENCE.png` | Issue #52 |
| **BUG-FR04-02** | Lỗ hổng leo quyền nghiêm trọng (Privilege Escalation): Người dùng tự thăng cấp Admin qua `PUT /api/users/me` (CWE-269) | **Critical** | `screenshots/FR04_BUG02_API_EVIDENCE.png` | Issue #53 |
| **BUG-FR04-03** | Lệch pha đặt tên trường camelCase ( `shippingAddress` ) vs snake_case ( `shipping_address` ) khiến địa chỉ bị null | **High** | `screenshots/FR04_BUG03_CODE_EVIDENCE.png` | Issue #54 |

### Chi tiết Bug tiêu biểu FR-04 Mobile:

1. **BUG-FR04-01: Regex số điện thoại sai ngược đặc tả**:
   - *Đặc tả*: "*Số điện thoại hợp lệ: bắt đầu bằng số 0, từ 10–11 chữ số*".
   - *Thực tế*: `App.js:287` dùng regex `/^[1-9][0-9]{8,9}$/` , bắt đầu bằng `[1-9]` và cấm số 0, khiến số điện thoại Việt Nam luôn bị từ chối.

- *Bằng chứng thực tế trên Mobile*:
  - Ảnh nhập số hợp lệ `0357131476`: `screenshots/FR04_BUG01_VALID_PHONE_INPUT.png`
  - Ảnh popup Alert từ chối: `screenshots/FR04_BUG01_INVALID_PHONE_REJECTED.png`
  - Ảnh phân tích code regex: `screenshots/FR04_BUG01_CODE_EVIDENCE.png`

2. **BUG-FR04-02: Lỗ hổng leo quyền Admin qua Profile Update**:
   - *Đặc tả*: "*Người dùng chỉ có thể cập nhật hồ sơ của chính mình; không thể tự thay đổi thuộc tính role*".
   - *Thực tế*: `server.js:124-127` cập nhật thẳng `role` từ request body vào CSDL SQLite.
   - *Bằng chứng*: `screenshots/FR04_BUG02_API_EVIDENCE.png`
3. **BUG-FR04-03: Lệch pha camelCase khiến mất địa chỉ giao hàng**:
   - *Thực tế*: Mobile gửi `{ shippingAddress }` nhưng backend trích xuất `{ shipping_address }`, dẫn đến biến này bị `undefined` và ghi đè `null` vào SQLite.
   - *Bằng chứng*: `screenshots/FR04_BUG03_CODE_EVIDENCE.png`